

附件 5:

供应商信息安全协议

甲
 方：

统一社会信用代码：

乙
 方：

统一社会信用代码：

鉴于甲乙双方签订关于信息化产品或服务的相关合同，为保障合作过程中甲方的信息安全，依据《中华人民共和国民法典》、《中华人民共和国网络安全法》、《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》及国家与地方有关法律法规的规定，双方经充分协商一致，达成下列信息安全条款。本条款为双方合作合同及项目的有效组成部分，与合同具有同等法律效力，乙方需严格恪守并履行。乙方必须确保，如果乙方人员在甲方经营/指定场所或甲方 IT 基础设施内提供服务，其人员必须始终遵守甲方通过任何形式披露的信息安全要求（含甲方制定的信息安全方针、政策及管理要求）。乙方同意，双方合作过程中涉及甲方关联公司的，乙方应按照本协议约定的同等标准向甲方关联公司承担信息安全责任与义务。

第一条 信息安全策略

- 1.1 乙方应制定全面的信息安全策略，遵循信息安全领域的最佳实践，例如采用 ISO27001 等国际标准，制定严格的信息安全方针和政策，实施有效的控制措施。
- 1.2 乙方制定的信息安全管理政策文件必须经过公司管理层的正式批准，并向所有员工和其相关方提供，以确保所有人都了解和遵守相关规定。
- 1.3 乙方应定期审查信息安全政策，以确保它的充分性、相关性和有效性，及时发现并解决任何潜在的安全问题。

1.4 乙方应为甲方项目指定专门的信息安全接口人，负责管理与甲方相关的所有产品或服务的信息安全事宜，确保所有信息安全策略、措施均符合甲方以任何形式披露的信息安全要求。乙方应定期开展信息安全意识培训活动，以提升其员工的信息安全意识。

1.5 乙方可通过获取相关安全资质证书来证明已具备相关的信息安全管理能力，如 ISO/IEC 27001、TISAX、SOC2、PCI-DSS 等，以提升自身在行业中的竞争力。

1.6 若项目中，乙方使用第三方（如分包商、合作伙伴）提供的产品或服务，应事先获得甲方的书面同意，应确保其所使用的第三方遵守本协议所述的信息安全要求，在此类情况下，乙方应对第三方的行为与疏失向甲方承担全部责任。

1.7 乙方应制定风险管理程序，对涉及甲方相关业务的信息安全风险进行识别，并采取必要措施控制和减轻相关信息安全风险。

第二条 人员安全

2.1 乙方须确保根据项目合同为甲方提供服务的乙方人员身份和联系方式等信息的准确性和有效性（包括电话号码、身份证号码、电子邮箱、地址）。甲方有权在项目合作、任何审计、纠纷处理或诉讼/仲裁过程中随时调用这些信息，以核实和确认已发放的访问权限（门禁、信息系统等）的有效性，或用于项目相关协议和法律法规未禁止的用途。

2.2 为确保项目的连续性和高效性，甲方会委派或聘请第三方共同参与或管理项目，在必要时，甲方有权将乙方人员的相关信息提供给第三方。

2.3 乙方应对其为甲方开展业务的人员实施信息安全意识培训，确保所有派往甲方工作环境的人员都充分了解在本协议项下的信息安全义务，理解和遵守对可访问的信息、设施和系统的使用规定，以避免任何未经授权的访问或泄露，从而保护甲方的商业秘密和敏感信息。

第三条 资产管理

3.1 乙方不得泄露任何甲方的涉密信息，除非在履行协议任务时必要，并且此类信息的披露必须向甲方进行事先申请，经甲方同意后披露信息严格控制在最低限度。

3.2 乙方需确保其信息处理设施的相关资产和控制措施得到明确识别、详细记录并严格执行，以保护甲方相关信息和资产。

3.3 乙方应确保项目履约过程中所使用的任何软件或工具（包括但不限于开源软件），均持有授权许可和合规，甲方均有权合规使用，否则由此引发的争议均由乙方自行承担。

3.4 乙方有责任保障甲方信息的安全性、完整性和一致性，严格遵守信息处理规程，防止信息泄露或损坏。

3.5 禁止乙方复制或篡改信息标记，确保信息所有者和安全级别的标识不被抹除或更改。

3.6 乙方在处理涉密信息时，需确保未经授权的人员无法轻易访问信息，采用安全措施，如加密、物理保护等。

3.7 乙方应根据甲方的要求，在项目合同到期或终止后，立即归还或销毁该项目合同项下与甲方相关的所有信息、软件和设备。乙方应通过书面、或签署协议的方式，向甲方证明其已归还或销毁与甲方相关的任何形式的软件、硬件或信息。对于根据法律或者监管要求需要保留甲方信息的情形，乙方应 1) 立即通知甲方，2) 根据本协议继续保护甲方信息，3) 非法律要求的场景，停止使用或处理甲方信息；乙方的上述义务在项目合同及本协议终止后仍然有效。

第四条 物理与环境安全

4.1 乙方在甲方的经营场所执行工作时，应始终了解并遵守甲方的信息安全要求。乙方有责任定期通知其员工、分包商适用于甲方经营场所的安全和安保规定，以及任何重大变更。

4.2 甲方的信息或资产在乙方的场所进行处理或存储，乙方应遵守以下规定：

4.2.1 托管甲方关键业务信息、应用程序和基础设施的数据中心应建立适合的物理和环境保护措施，以满足法律、法规和行业最佳实践的规定。

4.2.2 乙方应建立适当的入口控制和访问规则，以确保只有授权人员才能进入。

4.3 乙方访问甲方的物理区域应遵守以下规定：

4.3.1 乙方应按照甲方访问控制管理要求申请业务所需的访问的最小化区域，在区域访问过程中应携带必要的可识别标记，如访客卡。

4.3.2 项目完结、乙方人员调离、物件丢失等情况发生时，乙方应立即告知甲方、并配合甲方完成钥匙、门禁卡、证书、访客卡等业务过程中申请物件的归还或更改。

4.3.3 乙方出现违反此协议情况，甲方有权拒绝相关人员进入甲方的物理场所，并要求归还已发放的钥匙、门禁卡等。

第五条 网络安全

5.1 乙方人员在甲方场地办公，在未得到授权的情况下，只能使用甲方提供的访客网络。乙方自带设备原则上禁止接入甲方内部网络，若因特殊需求确需接入，必须事先向甲方申请，经甲方同意后方可接入，并应严格遵守甲方的终端安全管理规定，安装必要的安全管理软件或采用 VDI 方式访问。

5.2 严禁乙方在吉利网络环境中私自搭建局域网和服务器，如有此类需求，必须经过甲方的正式审批和报备。同时，乙方不得以任何形式（如 WI-FI 共享、自建 AP 等）将甲方网络暴露和共享至外部无线环境。

5.3 为保障信息安全，乙方必须具备有效的技术和管理手段，以及时发现并阻止相关人员进行可能破坏信息安全的行为，如入侵他人工作计算机、盗用他人账号、散播病毒和木马、攻击服务器和网络设施等。

第六条 数据安全

6.1 在合作过程中，乙方应确保仅可在符合法律法规规定且为完成合作所必须的范围内处理甲方数据。具体需要遵循以下数据安全要求：

- 6.1.1 数据采集：仅采集合同明确授权的数据，禁止超范围收集。需告知用户数据用途并获取同意（如涉及个人信息），建立数据校验机制，确保采集数据的准确性、完整性。
- 6.1.2 数据传输：数据应加密传输，使用 TLS 1.2 以上、VPN 等加密协议传输敏感数据。记录数据传输时间、对象、操作人员等信息，留存审计追溯。数据跨境传输应遵守所在国家或地区的法律法规要求。
- 6.1.3 数据存储：对静态数据采用 AES-256 等加密算法保护。应确保存储环境安全，若使用云存储，服务商必须通过 ISO 27001、云安全等信息安全资质认证。定期备份数据并测试恢复流程，确保业务连续性。
- 6.1.4 数据使用：数据使用须严格遵守与甲方签订合同的业务范围，不得超范围使用数据，在服务期间，乙方团队对数据的访问须遵循权限最小化原则，仅允许授权人员访问必要数据，实行分级授权管理。应监控数据处理行为，实时检测异常操作（如批量下载、非工作时间访问）。
- 6.1.5 数据共享：所有与第三方共享数据的行为，都必须经甲方书面同意，并通过甲方的信息安全、数据合规评审。共享数据涉及跨境的情形，在完成甲方信息安全、数据合规评审的基础上，需满足相关监管要求，如：中国《数据出境安全评估办法》或欧盟 GDPR 等适用法规。
- 6.1.6 数据销毁：服务结束时，应与甲方确认数据迁移及清除需求，经甲方确认方可进行数据清除，法规要求保留的情形需通知甲方。数据清除需使用物理销毁、多次覆写等技术彻底删除数据。并且向甲方提供数据销毁的书面证明或第三方认证报告。

第七条 系统开发安全

- 7.1 乙方在开发系统时（包括但不限于应用程序和 API），必须输入信息安全要求。应设计和实施适当的安全控制措施，如身份验证、会话管理、访问控制与授权、输入验证、输出编码/转义、通信加密、日志记录、隐私数据加密等。
- 7.2 乙方应制定正式的、有文件记录的变更发布控制程序，以防止未经授权的变更发布给信息系统带来损坏。
- 7.3 对现有系统的重大变更发布应遵循正式变更发布流程，确保现有实施的安全控制措施不受损害，并符合验证测试和安全测试的要求。

- 7.4 禁止乙方将生产环境中的甲方数据未经脱敏用于开发、测试环境使用。
- 7.5 系统或软件开发涉及代码、文档交付的，乙方应按照甲方要求，使用指定的工具并将成果物提交在指定位置。
- 7.6 乙方应保证其应用程序以及此类应用程序使用的任何组件不得包含计算机病毒、蠕虫、定时炸弹、后门、特洛伊木马或任何其他形式的恶意代码。
- 7.7 乙方应保证其开发的应用程序和使用的组件满足开源软件合规的要求，且不会出现高危漏洞。
- 7.8 乙方应对质保期内出现的系统安全问题负责，当系统被发现存在安全漏洞时，乙方应在三日内提供修复方案并主导安全整改修复工作；在质保期外，乙方应及时响应甲方需求，协助甲方完成安全整改修复工作。
- 7.9 乙方应收集和分析其所提供的产品或服务中，与信息安全威胁相关的威胁情报信息，包括但不限于战略威胁情报、战术威胁情报、运营威胁情报等。
- 7.10 乙方应对威胁情报定期进行分析，应根据威胁情报和风险分析结果，识别技术漏洞，并将最新补丁或应对方案及时通知甲方。

第八条 操作安全

- 8.1 乙方须全面实施并维护行业内的安全最佳实践，以保护甲方业务相关的信息、IT 资源、应用程序、平台、基础设施等技术细节免受任何信息安全事件的侵扰。
- 8.2 乙方须构建持续监控机制，对任何未经授权到的访问、使用或披露甲方信息或 IT 资源的行为进行检测，一旦核实有此类行为，应立即启动一切必要且适当的应对措施。
- 8.3 除非另有特别约定，乙方必须确保甲方的信息与其他业务合作伙伴的信息或访问严格隔离，实施有效的隔离措施，并施以相应的安全保护。对于甲方提出的特殊需求，还必须达到物理上的彻底隔离。
- 8.4 乙方应严格执行职责分离原则，确保未经明确授权或有效检测，任何人员都无法擅自访问、修改或利用甲方提供的 IT 资源。
- 8.5 乙方在处理与甲方相关的所有信息时，必须遵循以下规则：

8.5.1 纸质文件和可移动介质等应由授权人员进行安全控制，并实现相关的安全措施，如在不使用时将其存放在受管控的物理位置（如上锁的文件柜），并在传输过程采取必要的保护措施。

8.5.2 不允许在公共场所传播与甲方相关的涉密信息。

8.5.3 当传输甲方相关信息时，应确保数据传输的协议须 TLS1.2 以上，以保证数据传输的安全性。

8.6 乙方应采取监测、记录网络运行状态、网络安全事件的技术措施，留存相关的安全日志不少于六个月。

8.7 乙方应采取防范计算机病毒和网络攻击、网络入侵等危害网络安全行为的技术措施，确保甲方的信息受到妥善的安全保护。

8.8 乙方应确保所有与甲方信息相关的系统及组件保持最新的安全状态，建立补丁更新机制，及时更新安全补丁。

第八条 访问控制安全

8.1 乙方应仅在与甲方以书面形式明确约定的范围和要求下，才能访问甲方的 IT 资源、或场所，访问范围始终基于“知所必须，最小化”的原则，如人员有变更，乙方应在第一时间通知甲方。如未遵循上述协议要求，甲方有权撤销其访问资源的权利。

8.2 乙方应确保对甲方资源访问权限基于个人单独管控，并对访问的情况进行记录。

8.3 乙方应建立账号访问权限管理机制，至少每六个月审查一次与甲方数据相关的访问权限。

8.4 乙方应以安全的方式远程访问甲方数据存储的相关 IT 资源，此远程访问的方式和访问的设备应遵循行业的最佳实践，具备防病毒、数据防泄漏、通信加密等能力。

第九条 信息安全事件管理

9.1 乙方须制定事件管理职责与程序，以便发生信息安全事件能够及时且有效的响应。乙方一旦检测到与甲方相关的信息安全事件发生时，应立即通知甲方，并采取一切必要措施以减轻事件可能造成的损害。

9.2 乙方应在 24 小时内对信息安全事件进行风险分析，向甲方提供与信息安全事件相关的详细信息，包括但不限于信息安全事件的影响范围、采取的缓解和遏制措施，以及当前的事件调查进展。

9.3 当甲方发现与乙方相关的任何信息安全事件需要调查处理时，乙方应承担相应责任，全力配合甲方调查和处理信息安全事件。

第十条 信息安全方面的业务连续性管理

10.1 乙方应确保其在正常情况和紧急状态下具备全面的产品或服务的运营能力及充足的应急资源。

10.2 乙方应建立对甲方信息备份策略，备份的存储方式应确保恶意软件攻击无法访问这些数据，备份存储使用物理分离，如离线和异地数据存储。

10.3 乙方应建立冗余与容灾的能力，确保其服务的可用性。

10.4 乙方应制定业务连续性演练计划，对与甲方相关的业务系统进行应急演练，并保留相关的演练过程记录，以确保发生业务连续性中断可以进行及时恢复。

第十一条 安全审计

11.1 乙方应始终遵循甲方协议中规定的信息安全要求及法律法规规定的相关信息安全要求。

11.2 乙方应定期开展内部信息安全检查或审计以确保符合本协议中的信息安全要求。

11.3 若乙方未遵守协议要求，并且在收到甲方书面通知后 30 天内未纠正违约行为，甲方可在向乙方发出进一步通知后，部分或全部终止合同。为验证乙方是否遵循本协议要求，甲方有权对乙方发起审计，乙方收到书面通知后，有义务配合甲方的审计工作。

第十二条 违约责任以及损害赔偿

12.1 乙方或其人员违反本协议约定，给甲方造成损失或潜在信息安全威胁的，甲方根据乙方或其人员违约情形、损失程度、影响范围等综合判定乙方违约责任，并及时将处理结果告知乙方，若乙方有异议，应于收到通知后的【10】个工作日内提出书面意见、解释及证明资料，甲方收到乙方资料后进行评估，若甲方评估后不认可乙方提交的资料或乙方无法提交充分证据支持其异议的，违约责任判定结果以甲方第一次判定结果为准。

12.2 乙方违约，或经甲方判定信息安全事件需要乙方承担责任的，乙方应一次性向甲方支付违约金【30】万元（大写：【叁拾万元整】）或一次性向甲方所支付的违约金金额相当于甲乙双方签署的具体项目合同中约定的合同总金额/已发生合同总金额的 30%（两者取较高者）。

12.3 乙方或其人员违反本协议约定，其违约行为所获得的收益应当归甲方所有。同时应赔偿甲方经济损失，该等损失包括但不限于诉讼费用、律师费用以及其他合理的开支和甲方应当获得而未能获得的商业利益或机会补偿。

12.4 前述违约金、赔偿款等，乙方同意甲方直接在双方合作项目（合同）应付款项、履约保证金及质保金（若有）中扣除前述违约金。违约金不足以弥补甲方损失的，乙方应继续赔偿甲方的损失。扣除保证金后的 5 个工作日内，乙方应将保证金补足至对应项目合同第一部分约定的履约保证金（如有）与质量保证金（如有）金额。

12.5 因乙方或其人员违约，给甲方造成严重后果的，甲方将通过法律手段追究乙方责任，直至追究刑事责任。

第十三条 适用法律及争议解决

13.1 本协议适用于中华人民共和国法律法规。

13.2 凡因本协议产生的或与本协议相关的争议，双方应先通过友好协商解决；协商不成的，由甲方所在地人民法院管辖诉讼解决。

第十四条 其他

14.1 本协议各方均采用纸质盖章或均采用电子签章方式进行签署，本合同自各方纸质盖章并签字或加盖电子印章之日起生效。若均采用纸质盖章形式进行签署，本合同一式贰份，甲方执一份，乙方执一份，具有同等法律效力。

14.2 未尽事宜双方另行协商解决。

14.3 甲乙双方合作期间所有项目均受本协议条款约束。本协议不随甲乙双方合作（合同）的终止而终止。

14.4 如本协议版本发生变更，甲乙双方将按照新版本重新签署供应商信息安全协议。双方自新供应商信息安全协议生效之日起合作的项目，受新供应商信息安全协议条款约束。

（以下无正文）

甲方：	乙方：
法定代表人/授权委托人：	法定代表人/授权委托人：
地址：	地址：
电话：	电话：
开户行：	开户行：
账号：	账号：
签订日期：	签订日期：